



SafeNode Architecture and Data Flows

Reference architecture for the web, native clients, cryptography, backend, and third-party services.

Document version: 2026-07-27

Product: Safenode

Classification: Internal / customer-safe where noted

System context

Safenode consists of a client-heavy encryption boundary and a policy-oriented backend. Clients authenticate, derive or unwrap vault keys, encrypt and decrypt locally, and synchronize ciphertext. The backend authenticates sessions, enforces device and subscription policies, stores encrypted records, and integrates with external providers.

Layer	Primary components	Security role
Client	React/Vite, WebCrypto, hash-wasm, IndexedDB	Key derivation, encryption, local session memory
Identity	WebAuthn/passkeys, SSO, device sessions	Phishing-resistant authentication and trusted-device policy
API	Fastify, Zod, auth/device middleware	Validation, authorization, rate limits, audit events
Data	Prisma/Postgres	Encrypted blobs, metadata, credential records, subscription state
Platform	Cloudflare Pages, Railway	TLS edge delivery, API runtime, schema deployment
Providers	Paddle, Resend, Sentry	Billing, transactional email, error telemetry

Vault cryptography flow

- A random 256-bit vault key encrypts vault payloads with AES-GCM.
- Password unlock derives a key using the existing Argon2id/wrapped-key flow.
- Recovery-kit unlock uses the recovery-kit cryptographic path.
- Passkey PRF unlock uses WebAuthn PRF output, HKDF-SHA256, and AES-GCM to unwrap a per-credential wrapped vault key.
- Transient fields such as raw keys, salts, and access profiles are stripped before encryption/export.

The server synchronizes encrypted payloads and wrapped ciphertext; it is not a decryption service.

Authentication and device flow

- Signup/login establishes an authenticated session.
- A registered device is required for protected vault routes.
- Device limits and re-approval status are enforced server-side.
- Passkey vault unlock is available only when a server-authoritative PRF wrap exists and the browser/authenticator supports the required extension.
- Password and recovery-kit unlock remain fallback paths.

Team vault flow

- A team owner creates a team workspace subject to the team entitlement.
- Team membership and roles are stored server-side.
- The team vault payload is encrypted client-side and synchronized as ciphertext.
- Access requires the member identity, membership authorization, and the correct client-side secret/unlock material.
- Offboarding must revoke membership and rotate shared secrets according to the team operating procedure.

External trust boundaries

Provider	Data sent	Control
Paddle	Price IDs, customer email, subscription metadata, webhook events	Signed webhooks; no vault plaintext
Resend	Recipient, sender, email content	Verified sending domain; never include vault secrets
Sentry	Errors, breadcrumbs, limited user context	Scrub secrets and tokens; configure retention
Cloudflare	Web requests and static assets	TLS, headers, deployment access controls
Railway/Postgres	Encrypted blobs and account metadata	Private database networking, encrypted transport, least privilege